

우수검사실 신임인증 심사점검표

정보보안

가상인증원

이 책자는 데모용 가상 콘텐츠이며 실존 인증기관·심사문항과 무관한 무저작권 창작물입니다.

2027. 01

2027 년 개정판 변경내역 요약

(Summary of Changes)

정보보안

아래 심사문항들은 본 개정판에 신규 도입, 주요 문항/설명 수정 또는 삭제된 문항들입니다.

• 신규

문항번호 사유

-

• 수정

문항번호 수정유형

60.060.010 설명 수정

• 삭제

문항번호 사유

-

- **문항분류체계**

- 핵심문항 : C (Core standards)**

- 인증 유지에 결정적인 핵심 항목으로, 미충족 시 인증에 중대한 영향을 준다.

- 필요문항 : R (Required standards)**

- 적정 수준의 품질 확보를 위하여 갖추어야 하는 항목이다.

- 기본문항 : B (Basic standards)**

- 기본적으로 준수하여야 하는 항목으로 대부분의 문항이 이에 해당한다.

목 차

1. 보안 조직 및 교육
2. 자산식별 및 위험평가
3. 계정 및 접근권한
4. 네트워크 및 서버 보안
5. 악성코드 및 로그 관리
6. 백업 및 암호통제
7. 침해사고 대응
8. 외부자 보안 및 점검

1. 보안 조직 및 교육

문항 핵심C 60.010.010 정보보안 업무를 총괄하는 정보보안책임자를 지정하고 있는가?

배점

(3) 아니오

설명

- 정보보안책임자 지정 문서와 직무 기술을 확인한다.

문항 기본B 60.010.020 부서별 정보보안 담당자를 지정하고 그 역할과 책임을 문서로 정하고 있는가?

배점

(2) 아니오

설명

- 해당사항 없음

문항 기본B 60.010.030 전 임직원을 대상으로 연 1회 이상 정보보안 교육을 실시하고 있는가?

배점

(2) 아니오

설명

- 교육 계획과 실시 결과 기록을 확인한다. 정보보안 업무 담당자 대상 전문 교육 여부를 포함한다.

2. 자산식별 및 위험평가

문항 필요R 60.020.010 보유한 정보자산을 식별하여 정보자산 목록으로 관리하고 있는가?

배점

(3) 아니오

설명

- 정보자산 목록의 연 1회 이상 현행화 여부를 확인한다.

문항 기본B 60.020.020 정보자산에 기밀성, 무결성, 가용성을 고려한 중요도 등급을 부여하고 있는가?

배점

(2) 아니오

설명

- 해당사항 없음

문항 핵심C 60.020.030 연 1회 이상 정보자산에 대한 위험평가를 실시하고 있는가?

배점

(4) 아니오

설명

- 위험평가 계획, 수행 결과 보고서, 수용 불가 위험의 목록을 확인한다.

문항 필요R 60.020.040 위험평가 결과에 따른 위험 처리 계획을 수립하고 이행 현황을 반기별로 점검하고 있는가?

배점

(2.5) 아니오

설명

- 해당사항 없음

3. 계정 및 접근권한

문항 필요R 60.030.010 정보시스템 계정을 사용자별로 발급하고, 퇴직·전보 시 해당 계정을 지체 없이 회수하고 있는가?

배점

(3) 아니오

설명

- 공용 계정 사용 금지 여부와 계정 발급·회수 승인 기록을 확인한다.

문항 기본B 60.030.020 문자, 숫자, 특수문자를 조합하는 비밀번호 작성 규칙을 정하여 적용하고 있는가?

배점

(2) 아니오

설명

- 해당사항 없음

문항 필요R 60.030.030 접근권한의 적정성을 분기별 1회 이상 검토하고 불필요한 권한을 회수하고 있는가?

배점

(3) 아니오

설명

- 권한 검토 결과와 회수 조치 내역의 기록을 확인한다.

4. 네트워크 및 서버 보안

문항 필요R 60.040.010 업무망과 외부 인터넷 구간을 분리하는 등 네트워크 영역을 분리하여 운영하고 있는가?

배점

(3) 아니오

설명

- 해당사항 없음

문항 기본B 60.040.020 방화벽 등 보안장비의 정책을 반기별로 검토하여 불필요한 정책을 정비하고 있는가?

배점

(2) 아니오

설명

- 정책 검토 이력과 정비 결과를 확인한다.

문항 핵심C 60.040.030 운영체제와 소프트웨어의 보안 업데이트를 지체 없이 적용하고 그 내역을 기록하고 있는가?

배점

(4) 아니오

설명

- 보안 업데이트 적용 전 업무 영향도 검토 절차가 있는지 확인한다.

문항 기본B 60.040.040 서버를 보안 설정 기준에 따라 운영하고 불필요한 서비스와 계정을 제거하고 있는가?

배점

(2) 아니오

설명

- 해당사항 없음

5. 악성코드 및 로그 관리

문항 기본B 60.050.010 모든 업무용 단말과 서버에 백신 소프트웨어를 설치하고 최신 상태로 유지하고 있는가?

배점

(2) 아니오

설명

- 해당사항 없음

문항 필요R 60.050.020 주요 정보시스템의 접속 및 작업 로그를 수집하여 6개월 이상 위·변조 방지 조치와 함께 보관하고 있는가?

배점

(3) 아니오

설명

- 로그의 별도 보관 방법과 보관 기간을 확인한다.

문항 기본B 60.050.030 주요 시스템의 로그를 월 1회 이상 점검하고 이상 징후를 분석하고 있는가?

배점

(2) 아니오

설명

- 해당사항 없음

6. 백업 및 암호통제

문항 핵심C 60.060.010 주요 정보시스템의 데이터를 백업 정책에 따라 주기적으로 백업하고 있는가?

배점

(4) 아니오

설명

- 백업 매체를 원본과 물리적으로 분리된 장소에 보관하는지와 백업 수행 기록을 함께 확인한다.

문항 필요R 60.060.020 백업 데이터의 복구 가능 여부를 반기별 1회 이상 시험하고 그 결과를 기록하고 있는가?

배점

(3) 아니오

설명

- 해당사항 없음

문항 필요R 60.060.030 중요 정보를 안전성이 검증된 암호 알고리즘으로 암호화하여 저장·전송하고 있는가?

배점

(3) 아니오

설명

- 암호화 대상, 사용 알고리즘, 암호키 관리 절차를 정한 암호 통제 기준을 확인한다.

7. 침해사고 대응

문항 핵심C 60.070.010 침해사고 대응 절차를 수립하고 사고 유형별 보고 체계를 정하고 있는가?

배점

(4) 아니오

설명

- 해당사항 없음

문항 기본B 60.070.020 연 1회 이상 침해사고 대응 모의훈련을 실시하고 있는가?

배점

(2) 아니오

설명

- 해당사항 없음

문항 필요R 60.070.030 재해복구 계획을 수립하고 연 1회 이상 재해복구 훈련을 실시하고 있는가?

배점

(2.5) 아니오 해당없음

설명

- 별도의 재해복구 대상 시스템이 없는 기관은 해당없음으로 처리할 수 있다.

8. 외부자 보안 및 점검

문항 기본B 60.080.010 정보자산에 접근하는 외부 용역·유지보수 인력과 보안 준수 사항이 포함된 계약을 체결하고 접근을 통제하고 있는가?

배점

(2) 아니오 해당없음

설명

- 외부 인력의 정보자산 접근이 없는 기관은 해당없음으로 처리할 수 있다.

문항 필요R 60.080.020 정보보안 지침의 이행 실태를 연 1회 이상 점검하고 그 결과를 기관장에게 보고하고 있는가?

배점

(3) 아니오

설명

- 해당사항 없음